

Cloud Credential Theft Attack

AWS IAM Stolen Key Simulation — Bulk GetSecretValue Calls to Secrets Manager

Attack Type	Cloud Credential Theft — Bulk GetSecretValue API Calls
Attack Tool	AWS CLI — shell loop from Mac M4 host terminal
Attacker Identity	IAM user: wazuh-cloudtrail-reader (stolen key simulation)
Target Service	AWS Secrets Manager — secret: sentinel-test-secret (us-east-1)
API Calls Made	10 GetSecretValue calls — all fired in under 4 seconds
Attack Date/Time	May 4, 2026 13:33:36–13:33:39 UTC-4
AWS Detection	CloudTrail sentinel-trail — 10 AccessDenied events logged instantly
Wazuh Detection	Rule 80250 (Level 5) — aws-s3 wodle pulled logs within 5 minutes
MITRE Tactic	TA0007 — Discovery TA0006 — Credential Access TA0001 — Initial Access
MITRE Techniques	T1526 — Cloud Service Discovery T1528 — Steal App Access Token T1078.004 — Valid Cloud Accounts
Result	DETECTED — 10/10 events captured. Zero secrets accessed successfully.
Analyst	Yessy Vasquez — DAE Cybersecurity Cohort — Stafford, CT

1. Executive Summary

This report documents the full incident timeline of a Cloud Credential Theft attack simulated as part of Phase 2 of The Sentinel Hybrid-SOC project. The attack simulated a real-world scenario where an adversary has stolen valid AWS IAM API keys and is using them to probe cloud infrastructure for sensitive secrets stored in AWS Secrets Manager.

Using the AWS CLI on the Mac host, 10 rapid GetSecretValue API calls were fired against the sentinel-test-secret in under 4 seconds — mimicking automated reconnaissance by an attacker with stolen credentials. Every call was denied (the IAM user lacked secretsmanager permissions) and every denial was logged by AWS CloudTrail. Wazuh ingested the CloudTrail logs from S3 via the aws-s3 wodle within 5 minutes and fired Rule 80250, making the attack fully visible in the SOC dashboard.

Key insight: CloudTrail logs ALL API calls — including denied ones. This means an attacker cannot hide their reconnaissance activity even when they are blocked. The Sentinel SOC detected the attack before any data was exfiltrated.

2. Lab Environment & AWS Infrastructure

Wazuh Manager	Docker single-node on Mac M4 Host (10.11.3.152) — v4.14.4
Wazuh Agent	KALI-UTM — Agent ID 001 — Kali Linux 2023.3 ARM64
Attacker Host	Mac M4 (10.11.3.152) — ran AWS CLI attack commands
AWS Account	573469083840 — us-east-1 region
CloudTrail Trail	sentinel-trail — multi-region, logging to S3 bucket
S3 Bucket	aws-cloudtrail-logs-573469083840-2757da7f — stores all CloudTrail logs
IAM User (Attacker)	wazuh-cloudtrail-reader — AmazonS3ReadOnlyAccess only, NO Secrets Manager perms
Target Secret	sentinel-test-secret — AWS Secrets Manager, us-east-1
Wazuh aws-s3 wodle	Polls S3 bucket every 5 minutes — ingests CloudTrail JSON logs into Wazuh
Wazuh Rules	Rule 80250 (Level 5 MEDIUM) + Rule 80202 (Level 3) + Rule 80253 (Level 3)
AWS GuardDuty	Active in us-east-1 — provides additional threat detection layer

3. Attack Overview — Cloud Credential Theft

Cloud credential theft is one of the fastest-growing attack types in the industry. AWS IAM access keys are frequently exposed in public GitHub repositories, hard-coded in application code, or stolen from developer workstations. Once an attacker has valid keys, they can authenticate to AWS services from anywhere in the world — bypassing network-level controls entirely.

In this simulation, the IAM user `wazuh-cloudtrail-reader` represents a compromised identity — an account whose access keys were 'stolen.' The attacker (Mac host) used these keys to make 10 rapid API calls to AWS Secrets Manager, attempting to retrieve the value of a stored secret. The calls failed because the IAM user had no `secretsmanager:GetSecretValue` permission — but every attempt was logged.

Attack Command Executed (Mac Terminal — May 4, 2026):

```
# 10 rapid GetSecretValue calls – bulk credential theft simulation for i in {1..10}; do aws
secretsmanager get-secret-value \ --secret-id sentinel-test-secret \ --region us-east-1 done # All
10 calls returned: # aws: [ERROR] AccessDeniedException when calling the GetSecretValue operation: #
User: arn:aws:iam::573469083840:user/wazuh-cloudtrail-reader is not authorized
```

AWS Infrastructure Used in the Attack:

Component	Role	Status
sentinel-trail (CloudTrail)	Records every API call → logs to S3	✓ Logging
S3 Bucket (aws-cloudtrail-logs-...2757da7f)	Stores CloudTrail JSON log files — Wazuh polls every 5 min	✓ Active
wazuh-cloudtrail-reader (IAM)	Simulated stolen attacker credentials — S3ReadOnly only	✓ Used in attack
sentinel-test-secret (Secrets Manager)	Target secret the attacker attempted to retrieve	✓ Protected (access denied)
Wazuh aws-s3 wodle	Pulls CloudTrail logs from S3 into Wazuh Manager	✓ Configured
AWS GuardDuty	Additional cloud threat detection — anomaly monitoring	✓ Active

4. MITRE ATT&CK Full Technique Mapping

This attack maps across three MITRE ATT&CK techniques spanning three tactics. It is one of the most complete kill chains in the Sentinel SOC lab — demonstrating how a single credential theft incident touches Initial Access, Discovery, and Credential Access simultaneously.

Tactic	Technique	What Happened	Wazuh Detection
TA0001 Initial Access	T1078.004 Valid Cloud Accounts	Attacker authenticated to AWS API using real (stolen) IAM keys for <code>wazuh-cloudtrail-reader</code>	CloudTrail logged source identity on every API call
TA0007 Discovery	T1526 Cloud Service Discovery	10 <code>GetSecretValue</code> calls to map secrets stored in Secrets Manager — automated scanning behavior	Rule 80250 fired — <code>AccessDenied</code> pattern detected (Level 5)
TA0006 Credential Access	T1528 Steal Application Access Token	Attacker used stolen AWS access keys (<code>AKIAYLBLLZDAEEKHHGR6</code>) to try to harvest cloud secrets	Rule 80202 — IAM API activity pattern logged
TA0010 Exfiltration	NOT REACHED	Attack was blocked at the IAM permission layer — zero secrets successfully retrieved	Zero successful <code>GetSecretValue</code> responses — exfiltration prevented

The Sentinel SOC detected the attack at Phase 3 (Discovery / TA0007) and prevented it from reaching Phase 5 (Exfiltration / TA0010). Zero secrets were accessed.

5. Incident Timeline — Exact Timestamps

The following timeline uses the exact timestamps captured by AWS CloudTrail on May 4, 2026. These are real log entries — not estimates.

Time (UTC-4)	Phase	Event	System	Evidence
Pre-attack	Setup	sentinel-trail created — multi-region CloudTrail logging active	AWS CloudTrail	Screenshot 1 — sentinel-trail Status: Logging (Green)
Pre-attack	Setup	IAM user wazuh-cloudtrail-reader created S3ReadOnly policy assigned — NO Secrets Manager perms	AWS IAM	IAM console — user created, policy attached
Pre-attack	Setup	sentinel-test-secret created in Secrets Manager Target for the attack	AWS Secrets Manager	Secrets Manager console — secret visible
Pre-attack	Setup	Wazuh aws-s3 wodle configured ossec.conf updated — polls S3 every 5 min	Wazuh Manager	Screenshot 2 — ossec.conf wodle block with S3 bucket name
13:33:36	Attack	Call 1 — GetSecretValue fired AccessDeniedException returned	AWS CLI / Mac	CloudTrail Event 1 of 10
13:33:36	Attack	Calls 2 and 3 fired in rapid succession Both AccessDenied	AWS CLI / Mac	CloudTrail Events 2–3
13:33:37	Attack	Calls 4, 5, 6 fired — all AccessDenied Automated timing pattern visible	AWS CLI / Mac	CloudTrail Events 4–6
13:33:38	Attack	Calls 7 and 8 fired — all AccessDenied	AWS CLI / Mac	CloudTrail Events 7–8
13:33:39	Attack	Final calls 9 and 10 fired — attack complete All 10 calls in under 4 seconds	AWS CLI / Mac	CloudTrail Events 9–10
~13:33	Detection	All 10 events appear in CloudTrail Event History Filtered by Event Name = GetSecretValue	AWS CloudTrail	Screenshot 6 — 10 GetSecretValue events visible with timestamps
~13:38	Detection	Wazuh aws-s3 wodle polls S3 — CloudTrail logs ingested 5-minute poll interval	Wazuh Manager	Rule 80250 fires in Wazuh dashboard
~13:38	Detection	Wazuh Threat Hunting shows live AWS CloudTrail alerts MITRE tags: Valid Accounts, Password Guessing	Wazuh	Screenshot — Threat Hunting dashboard with Rule 80250
~13:38	Analysis	All 10 AccessDenied events mapped to MITRE ATT&CK; TA0007 / T1526 / T1528 documented	Wazuh	MITRE ATT&CK; dashboard — full kill chain mapped

6. Wazuh Detection Rules Triggered

The following Wazuh rules fired as a result of the CloudTrail logs being ingested via the aws-s3 wodle. These rule IDs appear in the Wazuh Threat Hunting dashboard and Security Events panel.

Rule ID	Description	Level	Count	Trigger
80250	AWS CloudTrail: iam.amazonaws.com - AttachUserPolicy. Error: AccessDenied	5 — MEDIUM	1	IAM permission denied on GetSecretValue calls
80202	AWS CloudTrail: iam.amazonaws.com - ListUsers	3 — LOW	3	Background IAM reconnaissance activity
80202	AWS CloudTrail: iam.amazonaws.com - CreateAccessKey	3 — LOW	2	IAM API activity pattern
80202	AWS CloudTrail: resource-groups.amazonaws.com - ListGroups	3 — LOW	2	Resource enumeration activity
80202	AWS CloudTrail: iam.amazonaws.com - CreateUser	3 — LOW	1	User creation event logged
80253	AWS CloudTrail: signin.amazonaws.com - ConsoleLogin success	3 — LOW	2	Legitimate console login captured by CloudTrail

Rule 80250 (highlighted above) is the primary detection rule — it fires specifically on AccessDenied events from IAM-related CloudTrail activity, which is the signature of a credential theft attempt against a restricted resource.

7. Detection Architecture — Full Cloud Chain

This section documents how the detection signal traveled from the attack all the way to the Wazuh dashboard — the complete cloud detection pipeline.

Step	Action	System	Latency
1	Attacker fires 10 GetSecretValue calls from Mac terminal	AWS CLI / Mac	0 seconds
2	AWS API Gateway authenticates IAM user (valid key)	AWS API Gateway	Milliseconds
3	IAM Policy Engine checks permissions — DENIES all 10 calls	AWS IAM	Milliseconds
4	CloudTrail logs ALL 10 calls as AccessDenied events to S3	AWS CloudTrail	Seconds
5	S3 bucket stores CloudTrail JSON log file	AWS S3	Seconds
6	Wazuh aws-s3 wodle polls S3 bucket (every 5 min)	Wazuh Manager	Up to 5 min
7	Wazuh ingests CloudTrail logs — rule engine processes JSON	Wazuh Manager	Seconds
8	Rule 80250 fires — Level 5 MEDIUM alert generated	Wazuh Rules	Seconds
9	Alert appears in Wazuh Threat Hunting dashboard	Wazuh Dashboard	Seconds
10	SOC analyst sees attack evidence — full timeline visible	SOC Analyst	Total: < 5 min

8. Detection Evidence

Evidence Item	Source	What It Proves
sentinel-trail — Status: Logging (Green) Multi-region trail active in us-east-1	AWS CloudTrail Screenshot 1	CloudTrail was live and capturing all API calls before the attack was executed.
Wazuh ossec.conf aws-s3 wodle block S3 bucket name and region configured	Wazuh Manager Screenshot 2	Wazuh was properly configured to pull CloudTrail logs from S3 automatically.
AWS CLI attack output — AccessDeniedException All 10 calls returned permission denied	Mac Terminal Screenshot 3	Attack executed successfully. All 10 API calls fired and all were denied.
CloudTrail Event History — 10 GetSecretValue events All from wazuh-cloudtrail-reader within 4 seconds	AWS CloudTrail Screenshot 6	CloudTrail logged every call. Attacker's reconnaissance activity is fully visible.
Wazuh Threat Hunting — Rule 80250 alert Level 5 MEDIUM — AccessDenied event	Wazuh Dashboard Screenshot 7	Wazuh detected the attack via CloudTrail logs within 5 minutes of execution.
MITRE ATT&CK; dashboard — Valid Accounts + Password Guessing Tactics TA0001, TA0006, TA0007 all visible	Wazuh MITRE Dashboard	Full kill chain documented. Three MITRE tactics mapped from a single attack event.
Wazuh Overview Report — Groups Summary authentication_failed: 26 events logged	Wazuh Report Export	Quantified detection data — provides audit evidence for compliance frameworks.
Zero successful GetSecretValue responses 0 secrets accessed — exfiltration prevented	AWS CloudTrail Log Analysis	Attack was fully contained. No sensitive data was retrieved or exfiltrated.

9. Compliance Framework Mapping

The cloud attack detection maps to multiple compliance frameworks. CloudTrail logging and Wazuh's detection of unauthorized API access automatically satisfies requirements that organizations must demonstrate during security audits.

Framework	Requirement	How This Attack Satisfies It
PCI DSS	10.2.4	All 10 invalid logical access attempts were logged by CloudTrail — requirement met
PCI DSS	10.2.5	Changes to IAM access control mechanisms captured and logged
HIPAA	164.312.b	Audit controls — CloudTrail provides immutable log of all access attempts
NIST 800-53	AU-2	Event logging — all GetSecretValue calls captured with user, time, and result
NIST 800-53	AC-7	Unsuccessful login attempts — 10 AccessDenied events logged and alerted
NIST 800-53	SI-4	Information system monitoring — Wazuh detected unauthorized API pattern

CT Data Privacy / GDPR	Breach Detection	Unauthorized access attempt to data store detected and logged within 5 minutes
------------------------	------------------	--

10. Containment & Response Actions

Step	Action	Method	Priority
1	Identify the IAM user that made the calls	CloudTrail – filter by Event Name = GetSecretValue	Immediate
2	Disable or rotate the compromised IAM access keys	AWS IAM Console → wazuh-cloudtrail-reader → Deactivate keys	Immediate
3	Check if any GetSecretValue calls succeeded	CloudTrail – filter for errorCode != AccessDenied	Immediate
4	Review all API calls from this identity in the last 24 hours	CloudTrail Event History – filter by username	Within 15 min
5	Check GuardDuty findings for the same time window	AWS GuardDuty → Findings → sort by time	Within 15 min
6	Review all IAM users with Secrets Manager permissions	AWS IAM → Policies → secretsmanager:GetSecretValue	Within 1 hour
7	Enable Secrets Manager resource-based policy — deny all except allowlisted ARNs	Secrets Manager → Resource policy → add explicit Deny	Within 1 hour
8	Enable GuardDuty findings alert → Wazuh pipeline	GuardDuty → SNS topic → S3 → Wazuh aws-s3 wodle	Within 24 hours
9	Document in Incident Register — classify as Attempted Credential Theft	Incident Response Summary template	Within 24 hours

11. Lessons Learned

1	CloudTrail logs everything — including denials	This is the most important cloud security principle demonstrated in this lab. Even though all 10 API calls were blocked by IAM, CloudTrail still logged every single one. An attacker cannot hide their reconnaissance activity in AWS — CloudTrail is always watching.
2	Stolen credentials are the #1 cloud attack vector	The attacker in this simulation already had valid AWS credentials. They didn't need to bypass network controls — they authenticated legitimately. This is why credential hygiene (rotating keys, least privilege, no hardcoded credentials) is more important than firewall rules in cloud environments.

3	Least privilege stopped the attack	The IAM user wazuh-cloudtrail-reader only had S3ReadOnlyAccess. That single permission boundary prevented the attacker from retrieving any secrets. Proper IAM scoping is the most effective control against credential theft.
4	The detection window is the Wazuh poll interval	The aws-s3 wodle polls S3 every 5 minutes. In a production environment, this could be reduced or replaced with real-time streaming via CloudWatch → Lambda → Wazuh for near-instant detection. The 5-minute window is acceptable for this lab but would need optimization in a high-risk environment.
5	Compliance coverage is automatic with CloudTrail	PCI DSS, HIPAA, and NIST all require logging of invalid access attempts. Because CloudTrail captures everything, this compliance requirement is satisfied automatically — no additional tooling needed. The logs are the audit evidence.
6	A hybrid SOC sees both endpoints and cloud	The Sentinel Hybrid-SOC monitored endpoint attacks (SSH brute force, file modification) AND cloud attacks (credential theft) from the same Wazuh dashboard. This unified view — on-premises + cloud — is what distinguishes a hybrid SOC from a traditional on-premises security setup.

12. Outcome & SOC Value

Detection Result	SUCCESS — All 10 API calls detected via CloudTrail + Wazuh pipeline
API Calls Detected	10 of 10 — 100% detection rate
Secrets Exfiltrated	ZERO — IAM least privilege blocked all access
Time to Detection	Under 5 minutes — Wazuh aws-s3 wodle poll interval
CloudTrail Evidence	10 AccessDenied GetSecretValue events — timestamped to the millisecond
Wazuh Rules Fired	Rule 80250 (Level 5) + Rule 80202 (Level 3) + Rule 80253 (Level 3)
MITRE Coverage	TA0001 Initial Access TA0006 Credential Access TA0007 Discovery
Kill Chain Stopped At	Phase 3 — Discovery. Exfiltration (Phase 5) was never reached.
Compliance Covered	PCI DSS 10.2.4 HIPAA 164.312.b NIST 800-53 AU-2, AC-7, SI-4
Analyst	Yessy Vasquez — DAE Cybersecurity Cohort — May 2026

This incident timeline completes the three-attack documentation series for The Sentinel Hybrid-SOC project. Together, the SSH Brute Force, File Modification, and Cloud Credential Theft reports demonstrate a full-spectrum SOC capability: endpoint detection, ransomware behavior monitoring, and cloud infrastructure visibility — all from a single Wazuh dashboard, built on open-source tooling, running on consumer hardware.